

## **Exercise Risk management**

### **CASE STUDY: LOYALTY PROGRAMME**

A large retailer is setting up a processing system for the management and monitoring of a loyalty programme reserved for adults. This processing uses an application to be installed on a smartphone and a dedicated website.

The processing aims in particular to manage :

- collecting and updating customers' personal data (via the mobile application or the dedicated website)
- assessing customer loyalty based on their purchase history,
- informing the customer in real time of the loyalty programme's achievements,
- monitor the transformation of acquired loyalty benefits,
- identify customer consumption habits,
- produce general statistics on consumption habits.

It is based on the following functionalities

- collect and modify the identification data of users who have voluntarily joined the programme, through the mobile application or via the dedicated website,
- collect and synchronise the history of purchases made in any of the company's shops in order to assess customer loyalty (e.g. list of products purchased, prices, frequency of purchases, etc.)
- reward user loyalty in the form of vouchers, loyalty points, gifts, etc., based on criteria such as frequency of purchases and amounts spent
- inform users in real time of their participation in the loyalty programme via push notifications,
- Track the use made by users of their loyalty rewards (loyalty points/product conversion),
- establish buyer profiles, based on users' consumption habits, in order to offer them loyalty rewards that correspond to their purchasing habits,
- to establish general and anonymous statistics relating to users' consumption habits.

### **Existing security measures**

Perimeters of personal data :

Storage of signed membership forms in a vault located in the offices of each outlet, with access restricted by badge.

Access control on the controller's side:

- The company's headquarters are equipped with an access control system using a badge and a reception desk.
- Access to workstations is secured by the use of a personal identifier associated with a password.
- The use of information systems within the company is governed by an IT Charter for all employees as well as by an "administrator" Charter specific to this category of employees.

Customer access control:

- Each customer has their own account, associated with the application they have downloaded onto their mobile device or associated with their web profile. Accesses to the application and actions performed by the client on the data are recorded in the application (log).
- Access to the application is protected by a password freely chosen by the customer.
- Internet connections are secured by end-to-end encryption. Perimeter of resources: data processing locations (collection, storage, backup, archiving and restitution).
- geographical areas concerned by cross-border flows: the application is hosted on the servers of a service provider located outside the EU (Tunisia).

Scope of business processes :

- Initial collection in shop.
- entry of data relating to membership of the loyalty programme.
- management of access to the personal space and to the computer systems and data.
- Management of cash receipts/checkouts (with access to the member number only).
- Management of shopping basket data (with reference to member number only).
- management of the current operation (including spreadsheet) and the development of the application.
- Management of the restitution and distribution methods.
- Management of data retention.

**1/ What are the 3 main risks that can occur in this department of the company?**

**2/ Place these 3 risks in a risk level matrix and explain your choices**